

REG-001: Incident reporting obligations (internal summary)

This is the bank's internal summary of its incident reporting obligations, prepared by Compliance for the fictional bank used in this project. It is synthetic and does not describe any real regulator's rules.

1. Which incidents are reportable

An incident is reportable when any of the following applies:

- A customer-facing payment or account service is unavailable or seriously degraded for more than 60 minutes.
- Customer funds or balances are, or may be, incorrect: duplicate debits or credits, missing postings, wrong amounts.
- Customer personal data may have been exposed.
- More than 5,000 customers are affected, whatever the duration.

Data-integrity incidents (duplicate or missing transactions) are always reportable, even when the technical impact looks small.

2. Deadlines

- Initial notification to the regulator: within 4 hours of the incident being classified as reportable.
- Intermediate report: within 72 hours, with the root cause if known and the number of customers affected.
- Final report: within 20 business days, with the confirmed root cause, remediation and preventive actions.

3. Who does what

- The incident commander tells the compliance officer as soon as an incident may be reportable. Do not wait for the root cause.
- The compliance officer decides whether the incident is reportable and submits the notifications.
- The service owner provides the impact figures: customers affected, amounts, duration.

4. Customer remediation

- Customers who were charged incorrectly must be refunded, and the refund must be completed within 2 business days of the error being confirmed.
- Customers must be told what happened in plain language, following REG-002.
- No fees or interest may result from the bank's error.

5. Records

Keep the incident timeline, the evidence used, every decision with its approver, and all customer communication for 7 years.